

Prasad's Notes for Cyber Security

SECURITY CONCEPTS

Complete Study Notes

Application Security | Ethical Hacking | Mobile Security

Duration: 60 Theory hrs + 50 Lab hrs + 10 hrs Self-Learning (Total 120 hrs)

Reference Text: Gray Hat Hacking - The Ethical Hacker's Handbook (Shon Harris, 5th Ed.)

Includes: Detailed Explanations • Diagrams & Charts • Highlighted Key Points • 40 Practice MCQs with Answers • 30-Question Quiz

Table of Contents

How to Use These Notes

Unit 1: Application (Web) Security

- 1.1 OWASP Top 10 (2021)
- 1.2 Injection and Inclusion Attacks
- 1.3 Cross-Site Scripting (XSS)
- 1.4 Denial of Service, Buffer Overflow & Access Control
- 1.5 Web Application Security Risks & Threat Risk Modelling
- 1.6 Data Extraction, SAST and DAST Tools

Unit 2: Ethical Hacking

- 2.1 Security Management Concepts & Principles
- 2.2 Threats and Attacks - Classification
- 2.3 Cyber Crimes & Legal Aspects
- 2.4 Introduction to Ethical Hacking (5 Phases)
- 2.5 Types of Hacker Classes
- 2.6 Foot-printing and Social Engineering / Scanning
- 2.7 Enumeration, Password Cracking & Tunneling
- 2.8 Trojans, Viruses, Worms & Spyware
- 2.9 Sniffing
- 2.10 DoS/DDoS Attacks & Session Hijacking
- 2.11 Hacking Web Servers & Wireless Networks
- 2.12 IDS, Honeypots, Firewalls, Physical Security & Pen Testing
- 2.13 Malware Reverse Engineering

Unit 3: Mobile Security

- 3.1 Introduction to Android Architecture
- 3.2 Android Debug Bridge (ADB) & Pen Testing Tools
- 3.3 OWASP Top 10 Mobile App Vulnerabilities
- 3.4 Attacks on Android Devices
- 3.5 Mobile Malware & App Analysis

Practice MCQs (40 Questions with Answers & Explanations)

Self-Test Quiz (30 Questions) + Answer Key

How to Use These Notes

These notes are written in simple English so that every student, even a beginner, can understand core security concepts without prior expertise. Follow this approach:

- Read the topic explanation first, then look at the diagram/table for quick visual memory.
- Boxes marked with a gold star (★ IMPORTANT) contain exam-critical points - revise these first.
- After each Unit, attempt the MCQs to self-test your understanding.
- At the end, a 30-question Quiz is provided (without answers shown inline) for self-assessment - treat it like a mock test.
- Practical/Lab topics are explained conceptually here; hands-on practice should be done in a lab environment (e.g., Kali Linux, DVWA, WebGoat) under supervision.

UNIT 1: APPLICATION (WEB) SECURITY

This unit covers how attackers break into websites and web applications, and how developers/testers find and fix these weaknesses (vulnerabilities) before hackers do.

1.1 OWASP Top 10 (2021)

OWASP (Open Web Application Security Project) is a non-profit that publishes a list of the 10 most critical web application security risks. Think of it as the 'most wanted list' of web vulnerabilities that every developer and tester must know.

#	Risk	Simple Explanation
A01	Broken Access Control	Users can access data/pages they should not be allowed to (e.g., viewing another user's account by changing an ID in the URL).
A02	Cryptographic Failures	Sensitive data (passwords, card numbers) is stored or sent without proper encryption.
A03	Injection	Untrusted input is sent to an interpreter (SQL, OS command) and executed as code, e.g. SQL Injection.
A04	Insecure Design	Security flaws built into the application's design itself, not just a coding bug.
A05	Security Misconfiguration	Default passwords, unnecessary features enabled, or misconfigured servers.
A06	Vulnerable and Outdated Components	Using old libraries/frameworks with known security holes.
A07	Identification and Authentication Failures	Weak login mechanisms allow attackers to guess passwords or hijack sessions.
A08	Software and Data Integrity Failures	Trusting updates/plugins/code from untrusted sources without verification.
A09	Security Logging and Monitoring Failures	Attacks go undetected because logs are missing or not monitored.
A10	Server-Side Request Forgery (SSRF)	Attacker tricks the server into making requests to unintended internal/external systems.

★ IMPORTANT: OWASP Top 10

#	Risk	Simple Explanation
- Injection (A03) and Broken Access Control (A01) are the most frequently asked topics in exams. - OWASP Top 10 is updated periodically - always mention '2021' version when asked, as ranks change over time.		

1.2 Injection and Inclusion Attacks

Injection happens when an application sends untrusted user input directly to an interpreter (like a database) without checking it first. The most common type is SQL Injection (SQLi).

SQL Injection (SQLi)

SQL Injection lets an attacker insert malicious SQL code into an input field (like a login box) to manipulate the database query.

Type	How it Works
Error-based SQLi	Attacker forces the database to throw an error message that reveals useful information (table names, structure).
Union-based SQLi	Uses the SQL 'UNION' operator to combine results of the attacker's query with the original query, extracting extra data.
Blind / Time-based SQLi	No error or data is shown directly; attacker asks true/false questions and observes response time or page behaviour to extract data bit by bit.

Classic example of bypassing login using SQL Injection: entering ' OR '1'='1' in the username field can make the query always evaluate to true, logging the attacker in without a valid password.

Inclusion Attacks

File Inclusion vulnerabilities (Local File Inclusion - LFI, Remote File Inclusion - RFI) occur when an application allows a file path to be controlled by user input, letting attackers include and execute unintended files (even malicious scripts hosted elsewhere).

1.3 Cross-Site Scripting (XSS)

XSS allows an attacker to inject malicious JavaScript into a trusted website, which then runs in another user's browser - stealing cookies, session tokens, or redirecting users to fake pages.

Type	Description
Reflected XSS	Malicious script is part of the URL/request and is immediately reflected back in the response (not stored). Victim must click a crafted link.
Stored XSS	Malicious script is permanently saved on the server (e.g., in a comment box) and served to every visitor - more dangerous.

Type	Description
DOM-based XSS	The vulnerability exists in client-side JavaScript itself; the script is executed by manipulating the page's DOM, without the server seeing the payload.
★ IMPORTANT: Injection vs XSS - Don't Confuse! - SQL Injection attacks the DATABASE. XSS attacks the BROWSER of other users. - Stored XSS is more dangerous than Reflected XSS because it affects every visitor automatically. - Prevention for both: input validation, output encoding, and parameterized queries (prepared statements) for SQLi.	

1.4 Denial of Service, Buffer Overflow & Access Control

Denial of Service (DoS)

A DoS attack floods a server/application with excessive requests or traffic so that legitimate users cannot access the service. When multiple systems attack together, it is called DDoS (Distributed Denial of Service).

Buffer Overflow and Input Validation

A buffer overflow happens when a program writes more data into a memory buffer than it can hold, overwriting adjacent memory. Attackers exploit this to crash a program or inject malicious code. Proper input validation (checking length, type, and format of input) is the main defence.

Access Control

Access control decides who is allowed to view or use resources. 'Broken Access Control' occurs when these checks are missing or can be bypassed, e.g., an ordinary user accessing an admin page by simply changing the URL.

1.5 Web Application Security Risks & Threat Risk Modelling

Threat Risk Modelling is the structured process of identifying what could go wrong in a system (threats), how serious the risk is, and what to do about it. A popular model used is STRIDE:

Letter	Threat Type
S	Spoofing identity
T	Tampering with data
R	Repudiation (denying an action)
I	Information Disclosure
D	Denial of Service
E	Elevation of Privilege

HTTP Fields

Understanding HTTP headers (Cookie, User-Agent, Referer, Authorization) helps testers spot weaknesses - e.g., missing security headers like Content-Security-Policy or X-Frame-Options.

Burp Suite

Burp Suite is the most widely used tool for web application security testing. Key features:

- Proxy - intercepts and modifies requests between browser and server.
- Spider - automatically crawls a web application to map its structure.
- Scanner - automatically finds common vulnerabilities.
- Intruder - automates customized attacks (e.g., brute force, fuzzing).
- Repeater - manually resend and tweak individual requests.

1.6 Data Extraction, SAST and DAST Tools

Data Extraction / Advanced Exploitation refers to techniques attackers use to pull sensitive data out of a vulnerable application once they've found a weakness.

Aspect	SAST (Static)	DAST (Dynamic)
Full Form	Static Application Security Testing	Dynamic Application Security Testing
When Used	Analyses source code without running the app	Tests the running application from outside (black-box)
Finds	Coding-level flaws early (before deployment)	Runtime issues, configuration, and environment flaws
Example Tools	Checkmarx, Fortify	OWASP ZAP, Burp Suite

★ IMPORTANT: SAST vs DAST - Quick Memory Trick

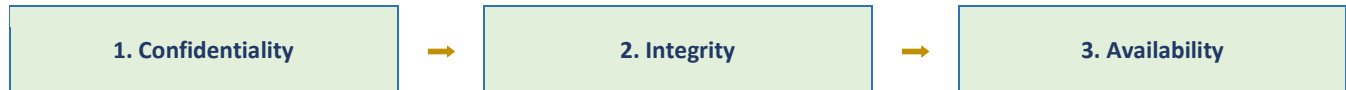
- SAST = 'Source code' (White-box) - done early in development, like proof-reading code.
- DAST = 'Doing it live' (Black-box) - done after the app is running, like testing a finished car by driving it.

UNIT 2: ETHICAL HACKING

Ethical Hacking means legally breaking into systems (with permission) to find weaknesses before real (malicious) attackers do. This unit covers security fundamentals, hacker types, attack techniques, and defence tools.

2.1 Security Management Concepts & Principles

All information security is built around three core goals, known as the CIA Triad:



Principle	Meaning
Confidentiality	Only authorized people can view the data (protected using encryption, access control).
Integrity	Data is accurate and unaltered (protected using hashing, checksums).
Availability	Data/systems are accessible when needed (protected against DoS attacks, backups).

The 'human side' of information security recognizes that people (through carelessness or social engineering) are often the weakest link, even when technical controls are strong.

2.2 Threats and Attacks - Classification

Category	Examples
Natural/Physical Threats	Fire, floods, power failure, hardware theft
Human Threats (Unintentional)	Employee mistakes, misconfiguration
Human Threats (Intentional)	Hacking, insider attacks, malware, fraud
Network/Software Threats	Viruses, worms, Trojans, DoS attacks

2.3 Cyber Crimes & Legal Aspects

Cyber Crime is any illegal activity carried out using computers or the internet - hacking, fraud, mischief, obscenity, etc.

- Indian IT Act 2000 - the main law dealing with cyber crimes in India (hacking, data theft, cyber fraud).
- Indian Penal Code (IPC) - certain traditional sections (like fraud, forgery, defamation) also apply to cyber offences.
- International Law - cyber crime often crosses borders, so international cooperation (e.g., Budapest Convention) is important.
- Obscenity & Pornography laws apply strictly to online content as well as offline.

★ IMPORTANT: Cyber Law

- The IT Act 2000 (India) is the most exam-relevant law - remember it covers hacking, data theft, and electronic fraud.

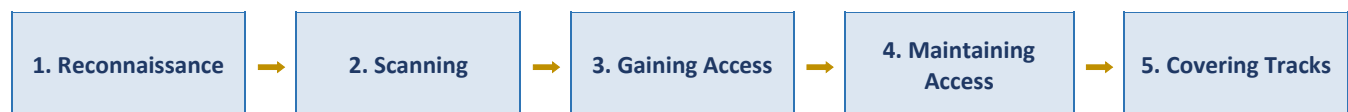
- Cyber crime is often trans-national - the attacker and the victim may be in different countries, making jurisdiction tricky.

2.4 Introduction to Ethical Hacking

Ethical Hacking terminology to remember:

Term	Meaning
Vulnerability	A weakness that can be exploited
Exploit	A piece of code/technique that takes advantage of a vulnerability
Threat	A potential danger that could exploit a vulnerability
Payload	The part of malware/exploit that performs the malicious action
Zero-day	A vulnerability unknown to the vendor, with no patch available yet

The 5 Phases of Ethical Hacking



- Reconnaissance (Foot-printing) - gathering information about the target (passive: public info; active: direct probing).
- Scanning - actively probing the target to find live hosts, open ports, and services.
- Gaining Access - actually exploiting a vulnerability to break in.
- Maintaining Access - installing backdoors/Trojans so the attacker can return later.
- Covering Tracks - deleting logs and hiding evidence of the intrusion.

2.5 Types of Hacker Classes

Type	Description
White Hat / Ethical Hacker	Hacks with permission to find and fix vulnerabilities
Black Hat / Cracker	Hacks illegally for personal gain or malicious intent
Grey Hat	Sometimes acts illegally but without malicious intent; may hack without permission then report it
Red Team	Simulates real attackers to test an organization's defences (offense)
Blue Team	Defends the organization, monitors and responds to attacks (defense)

★ **IMPORTANT: Hacker Classes - Key Distinction**

Type	Description
• Ethical Hacker vs Cracker: BOTH may have similar skills, but permission and intent make all the difference. • Red Team = Attackers (offense) Blue Team = Defenders (defense) Purple Team = combines both.	

Security, Functionality and Ease-of-Use Triangle: increasing one typically decreases another - e.g., stronger security often makes a system less convenient to use. A good design balances all three.

2.6 Foot-printing and Social Engineering

Foot-printing is the process of collecting as much information as possible about a target before attacking - like a burglar studying a house before breaking in.

- Traceroute - shows the path/hops data takes to reach the target, revealing network structure.
- WHOIS - reveals domain registration details (owner, registrar, name servers).
- Google Dorks - using advanced Google search operators to find exposed/sensitive information.
- Social Engineering - manipulating people (not computers) into revealing confidential information, e.g., phishing calls or emails.

Scanning Types

Port Scanning finds open ports; Network Scanning finds live hosts; Vulnerability Scanning finds known weaknesses.

Scan Type	How it Works
SYN Scan	Sends SYN packet, if SYN-ACK received port is open, but never completes the handshake (stealthy/half-open)
Stealth Scan	Designed to avoid detection by firewalls/IDS
XMAS Scan	Sends packets with FIN, URG, PSH flags all set ('lit up like a Christmas tree')
NULL Scan	Sends packets with no flags set at all
IDLE Scan	Uses a third 'zombie' host to scan a target anonymously
FIN Scan	Sends a packet with only the FIN flag set

2.7 Enumeration, Password Cracking & Tunneling

Enumeration is extracting detailed information such as usernames, machine names, shares, and services once a connection to the target is established.

Concept	Explanation
Banner Grabbing	Capturing service banners to identify software/OS versions running on a target
OS Fingerprinting	Identifying the target's operating system based on network responses

Concept	Explanation
Proxy Servers in Attacks	Used to hide the attacker's real IP address and location
HTTP Tunneling	Wrapping other protocols inside HTTP to bypass firewalls
IP Spoofing	Forging the source IP address to impersonate another machine
SMB Relay / MITM	Redirecting SMB logon requests to intercept or relay credentials

Password Cracking Techniques

Technique	Description
Dictionary Attack	Tries passwords from a pre-made word list
Brute Force Attack	Tries every possible combination of characters
Rainbow Table Attack	Uses precomputed hash tables to quickly reverse password hashes
Active Online Attack	Directly interacting with the target system to guess credentials (e.g., login attempts)
Passive Online Attack	Capturing credentials by listening to network traffic (sniffing)
Offline Attack	Cracking password hashes after they've been stolen, without touching the live system
★ IMPORTANT: Password Cracking - Countermeasures • Strong password policy + account lockout after failed attempts. • Multi-Factor Authentication (MFA) defeats most password-cracking techniques even if the password is stolen. • Salting hashes prevents Rainbow Table attacks from working easily.	

2.8 Trojans, Viruses, Worms & Spyware

Malware Type	Key Feature
Trojan	Disguised as legitimate software; does not self-replicate; often creates a backdoor
Virus	Attaches itself to a host file/program and needs human action (e.g., opening file) to spread
Worm	Self-replicates and spreads automatically across networks WITHOUT needing a host file or human action

Malware Type	Key Feature
Spyware/Keylogger	Secretly monitors and records user activity (keystrokes, screenshots)

★ **IMPORTANT: Virus vs Worm - Most Asked Question!**

- VIRUS needs a host file and human action to spread (like attaching to an email attachment).
- WORM spreads BY ITSELF across a network - no human action or host file needed. This is why worms spread much faster.
- Overt Channel - a normal, legitimate communication path.
- Covert Channel - a hidden communication path used to secretly transfer data/instructions, bypassing security policy.
- Reverse-connecting Trojan - the infected machine initiates the connection OUT to the attacker (bypassing inbound firewall rules).
- Netcat - a versatile networking tool often abused to create backdoors and reverse shells.
- System File Verification - checking file integrity (hashes) to detect if system files have been tampered with by a Trojan/virus.

2.9 Sniffing

Sniffing captures data packets as they travel across a network - like wiretapping a phone line.

Type	Description
Active Sniffing	Used on switched networks; requires injecting traffic (e.g., ARP poisoning) to intercept data
Passive Sniffing	Used on hub-based networks; simply listens to traffic without sending anything

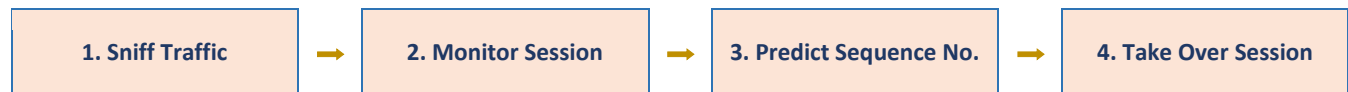
- ARP Poisoning - sending fake ARP messages to associate the attacker's MAC address with a victim's IP, redirecting traffic through the attacker.
- MAC Flooding - overwhelming a switch's MAC address table so it starts broadcasting traffic to all ports like a hub (making sniffing easy).
- DNS Spoofing - providing false DNS responses to redirect users to malicious websites.
- Protocols vulnerable to sniffing: HTTP, FTP, Telnet (they send data in plain text, unlike HTTPS/SSH).

2.10 DoS/DDoS Attacks & Session Hijacking

Attack	Description
SYN Flooding	Sends many SYN requests without completing the handshake, exhausting server resources
Smurf Attack	Sends ICMP requests with a spoofed victim IP to a broadcast address, flooding the victim with replies
Botnet/BOT	A network of infected 'zombie' computers controlled remotely to launch large-scale (DDoS) attacks

Spoofing vs Hijacking: Spoofing means pretending to be someone else BEFORE a session is established; Hijacking means taking over an ALREADY established, valid session (e.g., stealing a session cookie/token).

Steps to Perform Session Hijacking



2.11 Hacking Web Servers & Wireless Networks

Web servers can be attacked through misconfigurations, weak passwords, and unpatched vulnerabilities.

Wireless Hacking

Protocol	Security Level
WEP (Wired Equivalent Privacy)	Old and weak; easily cracked using known tools within minutes
WPA (Wi-Fi Protected Access)	Stronger than WEP but still has known weaknesses
WPA2/WPA3	Current secure standards (not deeply covered in this syllabus but good to know)

- SSID - the name of a wireless network; can be hidden but still discoverable using wireless sniffers.
- MAC Spoofing - changing a device's MAC address to bypass MAC-based access control on a Wi-Fi network.

2.12 IDS, Honeypots, Firewalls, Physical Security & Penetration Testing

Defence Tool	Function
Firewall	Filters incoming/outgoing traffic based on rules; acts as a barrier between trusted and untrusted networks
IDS (Intrusion Detection System)	Monitors traffic and ALERTS on suspicious activity (does not block)
IPS (Intrusion Prevention System)	Monitors traffic and actively BLOCKS suspicious activity
Honeypot	A decoy system designed to attract and trap attackers, so their techniques can be studied

Physical Security protects the actual hardware, buildings, and equipment - locks, biometric access, CCTV, security guards. Factors affecting it include location, natural disasters, and human threats (theft, sabotage).

Penetration Testing Methodology

Penetration Testing (Pen Testing) is a simulated, authorized cyberattack performed to evaluate the security of a system. Common methodology: PTES (Penetration Testing Execution Standard) - includes Pre-engagement, Reconnaissance, Threat Modelling, Vulnerability Analysis, Exploitation, Post-Exploitation, and Reporting.

2.13 Malware Reverse Engineering

Reverse Engineering means analysing malware to understand how it works, what it does, and how to detect/remove it.

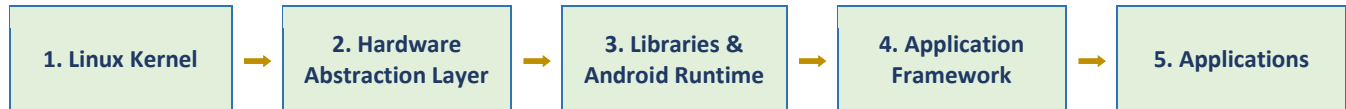
Analysis Type	Description
Static Analysis	Examining the malware's code WITHOUT running it (e.g., disassembling, reading strings)
Dynamic Analysis	RUNNING the malware in a safe, isolated environment (sandbox) and observing its behaviour
★ IMPORTANT: Unit 2 - Must-Remember Points ● 5 Phases of Hacking: Reconnaissance -> Scanning -> Gaining Access -> Maintaining Access -> Covering Tracks. ● Worm spreads on its own; Virus needs a host file and human action. ● IDS detects & alerts; IPS detects & blocks - this is the #1 confusion point in exams. ● SAST = code-level (before running); DAST = running application (black-box).	

UNIT 3: MOBILE SECURITY

With smartphones holding huge amounts of personal data, mobile security has become critical. This unit focuses on Android, since it is the most widely used and studied mobile OS in security courses.

3.1 Introduction to Android Architecture

Android is built in layers, like a stack. Each layer depends on the one below it:



Layer	Purpose
Linux Kernel	Manages hardware, memory, process, and provides core security (permissions, sandboxing)
Hardware Abstraction Layer (HAL)	Provides standard interfaces to hardware (camera, Bluetooth, etc.)
Android Runtime (ART) & Libraries	Executes app code; includes core libraries (SQLite, WebKit, etc.)
Application Framework	APIs that developers use to build apps (Activity Manager, Content Providers)
Applications	The apps end-users interact with (system apps + user-installed apps)

Android File Structure & Build Process

An Android app is packaged as an APK (Android Package) file - essentially a ZIP file containing compiled code (DEX files), resources, assets, and a manifest file (AndroidManifest.xml) that declares permissions and components.

Build Process (simplified): Source Code -> Compiled to bytecode -> Packaged with resources -> Signed with a certificate -> Final APK ready to install.

Android Security Model

- Sandboxing - each app runs in its own isolated environment and cannot access another app's data directly.
- Permission System - apps must explicitly request permission (camera, contacts, location) to access sensitive resources.
- App Signing - every app must be digitally signed; this verifies the developer's identity and app integrity.

Device Rooting

Rooting gives a user full administrative (superuser) control over the Android OS, bypassing built-in restrictions. While it allows deep customization, it also disables key security protections (like sandboxing), making rooted devices much more vulnerable to malware.

★ IMPORTANT: Rooting - Key Exam Point

- Rooting = removing manufacturer restrictions to gain full control, similar to 'jailbreaking' on iOS.
- A rooted device loses many built-in Android security protections, making it an easier malware target.

3.2 Android Debug Bridge (ADB) & Penetration Testing Tools

ADB (Android Debug Bridge) is a command-line tool that lets developers/testers communicate with an Android device (real or emulated) - installing apps, debugging, and even extracting data if security is weak.

Tool	Purpose
ADB	Communicate with and control a connected Android device via commands
APKTool / JADX	Decompile an APK to view/analyse its source code (reverse engineering)
Frida	Dynamic instrumentation - hook into and inspect an app's behaviour while it runs
MobSF	Automated static and dynamic security analysis of mobile apps

3.3 OWASP Top 10 Mobile App Vulnerabilities

Risk	Simple Explanation
Improper Platform Usage	Misusing a platform feature or failing to use platform security controls
Insecure Data Storage	Sensitive data stored in plain text on the device (easily readable if device is lost/rooted)
Insecure Communication	Data sent over the network without proper encryption (no HTTPS/TLS)
Insecure Authentication	Weak or bypassable login/session mechanisms in the app
Insufficient Cryptography	Using weak or broken encryption algorithms
Insecure Authorization	Failing to properly check what an authenticated user is allowed to do
Client Code Quality	Coding flaws in the mobile client causing security bugs (e.g., buffer overflows)
Code Tampering	App's code is modified (repackaged) by an attacker to insert malicious behaviour
Reverse Engineering	Attacker decompiles the app to understand logic, find secrets (API keys), or clone it
Extraneous Functionality	Hidden backdoor/debug features left in the production app by mistake

★ IMPORTANT: Mobile Top 10 - Most Common Exam Focus

- Insecure Data Storage is the most frequently tested risk - remember: never store passwords/tokens in plain text on the device.
- Insecure Communication is fixed by always enforcing HTTPS/TLS with certificate pinning.

3.4 Attacks on Android Devices

Attack Category	Examples
Web-Based Attacks	Phishing pages, malicious redirects opened via mobile browser
Network-Based Attacks	Man-in-the-Middle (MITM) attacks, packet sniffing on unsecured Wi-Fi
Social Engineering	Smishing (SMS phishing), fake app installs, fraudulent calls/messages

Smishing = 'SMS' + 'Phishing' - tricking users through text messages into clicking malicious links or revealing personal information.

3.5 Mobile Malware & App Analysis

Mobile malware behaves similarly to desktop malware but is specially crafted to abuse mobile-specific permissions like SMS access, contacts, camera, and location.

- Static Analysis of Android Apps - examining the APK's code/manifest without running it (using APKTool, JADX).
- Dynamic Analysis of Android Apps - running the app in a monitored/sandboxed environment (e.g., using MobSF or an emulator) and observing its real-time behaviour (network calls, permission use).

★ IMPORTANT: Unit 3 - Must-Remember Points

- Android layers (bottom to top): Linux Kernel -> HAL -> Libraries/ART -> Application Framework -> Applications.
- Rooting removes security restrictions and increases malware risk.
- OWASP Mobile Top 10 mirrors OWASP Web Top 10 in spirit but is mobile-specific (data storage, communication, reverse engineering).
- MobSF = combined static + dynamic mobile app security testing tool.

PRACTICE MCQs (40 Questions with Answers & Explanations)

These 40 questions cover the entire syllabus (Web Application Security, Ethical Hacking, and Mobile Security) and include a mix of easy, moderate, and tricky questions to test deep understanding, not just memorization.

Q1. Which OWASP Top 10 (2021) category covers SQL Injection? *[Easy]*

- A) A02 - Cryptographic Failures
- B) A03 - Injection
- C) A05 - Security Misconfiguration
- D) A08 - Software and Data Integrity Failures

Correct Answer: B

Explanation: SQL Injection falls under the 'Injection' category (A03) because untrusted input is executed by the database interpreter.

Q2. What is the key difference between Stored XSS and Reflected XSS? *[Moderate]*

- A) Stored XSS only works on HTTPS sites
- B) Stored XSS is saved on the server and affects all visitors; Reflected XSS requires a crafted link per victim
- C) Reflected XSS is more dangerous than Stored XSS
- D) There is no difference

Correct Answer: B

Explanation: Stored XSS persists on the server (e.g., in a comment) and attacks every visitor automatically, making it more dangerous than Reflected XSS, which needs the victim to click a specific malicious link.

Q3. A tester enters ' OR '1'='1 into a login form and successfully bypasses authentication. This demonstrates: *[Easy]*

- A) Cross-Site Scripting
- B) Buffer Overflow
- C) SQL Injection
- D) Denial of Service

Correct Answer: C

Explanation: This classic payload manipulates the SQL query's logic to always be true, which is a textbook SQL Injection technique.

Q4. Which testing approach analyses source code WITHOUT executing the application? *[Moderate]*

- A) DAST
- B) SAST
- C) Penetration Testing
- D) Fuzz Testing

Correct Answer: B

Explanation: SAST (Static Application Security Testing) reviews source code directly, without running the program - unlike DAST which tests a running (live) application.

Q5. Burp Suite's 'Intruder' tool is primarily used for: *[Moderate]*

- A) Automating customized attacks like brute force and fuzzing
- B) Only viewing HTTP headers
- C) Editing images in a web page
- D) Generating SSL certificates

Correct Answer: A

Explanation: Intruder automates sending repeated, customized requests - useful for brute-forcing logins or fuzzing input fields to find vulnerabilities.

Q6. Which of these is NOT one of the CIA Triad principles? *[Easy]*

- A) Confidentiality
- B) Integrity
- C) Availability
- D) Accountability

Correct Answer: D

Explanation: The CIA Triad consists of Confidentiality, Integrity, and Availability. Accountability is a related but separate security concept (often part of AAA - Authentication, Authorization, Accounting).

Q7. What is the correct order of the 5 phases of (ethical) hacking? *[Easy]*

- A) Scanning, Reconnaissance, Gaining Access, Covering Tracks, Maintaining Access
- B) Reconnaissance, Scanning, Gaining Access, Maintaining Access, Covering Tracks
- C) Gaining Access, Reconnaissance, Scanning, Maintaining Access, Covering Tracks
- D) Reconnaissance, Gaining Access, Scanning, Covering Tracks, Maintaining Access

Correct Answer: B

Explanation: The standard order is: Reconnaissance -> Scanning -> Gaining Access -> Maintaining Access -> Covering Tracks.

Q8. A 'Grey Hat' hacker is best described as someone who: *[Moderate]*

- A) Always has malicious intent
- B) Hacks only with full legal authorization at all times
- C) May hack without permission but generally without malicious intent, sometimes reporting findings afterward
- D) Works exclusively for law enforcement

Correct Answer: C

Explanation: Grey Hat hackers occupy a middle ground - they may break into systems without authorization but typically do not have malicious intent, sometimes disclosing vulnerabilities afterward.

Q9. Which scan sends packets with the FIN, URG, and PSH flags all set? *[Tricky]*

- A) NULL Scan
- B) SYN Scan
- C) XMAS Scan
- D) IDLE Scan

Correct Answer: C

Explanation: The XMAS scan is named because the packet is 'lit up' with multiple flags (FIN, URG, PSH) set simultaneously, like a Christmas tree.

Q10. What is the main difference between a Virus and a Worm? *[Moderate]*

- A) A Virus spreads without any host file; a Worm needs a host file
- B) A Worm self-replicates and spreads across a network without human action; a Virus needs a host file and human action to spread
- C) They are exactly the same thing
- D) Only Worms can infect mobile devices

Correct Answer: B

Explanation: This is a classic distinction: Worms spread autonomously across networks, while Viruses require attachment to a host file and some human action (like opening the file) to propagate.

Q11. Which tool/technique allows an attacker to associate their MAC address with a victim's IP address on a LAN? *[Moderate]*

- A) DNS Spoofing
- B) ARP Poisoning
- C) SYN Flooding
- D) Smishing

Correct Answer: B

Explanation: ARP Poisoning sends forged ARP replies to bind the attacker's MAC address to the victim's IP, redirecting traffic through the attacker's machine (a Man-in-the-Middle setup).

Q12. What is the key functional difference between an IDS and an IPS? *[Moderate]*

- A) IDS blocks attacks; IPS only alerts
- B) IDS only alerts on suspicious traffic; IPS actively blocks it
- C) Both only alert, never block
- D) Both only block, never alert

Correct Answer: B

Explanation: IDS (Intrusion Detection System) monitors and alerts administrators, while IPS (Intrusion Prevention System) actively blocks the detected malicious traffic in real time.

Q13. A Smurf Attack primarily exploits which protocol? *[Tricky]*

- A) HTTP
- B) ICMP
- C) FTP
- D) DNS

Correct Answer: B

Explanation: A Smurf attack sends ICMP echo requests to a broadcast address with the victim's IP spoofed as the source, causing many hosts to flood the victim with ICMP replies.

Q14. What best differentiates Spoofing from Session Hijacking? *[Tricky]*

- A) Spoofing happens after a session exists; Hijacking happens before
- B) Spoofing is pretending to be someone else before a session starts; Hijacking is taking over an already established session
- C) They mean exactly the same thing
- D) Spoofing only applies to emails

Correct Answer: B

Explanation: Spoofing involves impersonation before/without an existing session, while Session Hijacking takes control of a session that is already authenticated and active.

Q15. WEP (Wired Equivalent Privacy) is considered insecure mainly because: *[Moderate]*

- A) It does not support Wi-Fi at all
- B) Its encryption can be cracked quickly using known tools/techniques
- C) It only works on wired networks
- D) It was never implemented in real products

Correct Answer: B

Explanation: WEP uses a weak encryption implementation (RC4 with weak IV handling) that can be cracked within minutes using widely available tools.

Q16. A Honeypot is best described as: *[Easy]*

- A) A tool to encrypt sensitive data

- B) A decoy system designed to attract and study attackers
- C) A type of firewall rule
- D) A password cracking technique

Correct Answer: B

Explanation: A Honeypot is a deliberately vulnerable-looking system set up to lure attackers, allowing defenders to study their techniques without risking real assets.

Q17. Which malware analysis method involves actually running the malware in an isolated environment? *[Easy]*

- A) Static Analysis
- B) Dynamic Analysis
- C) Passive Analysis
- D) Manual Analysis

Correct Answer: B

Explanation: Dynamic Analysis executes the malware in a sandboxed/controlled environment to directly observe its real behaviour, unlike Static Analysis, which examines code without running it.

Q18. In the Android architecture, which layer sits directly above the Linux Kernel? *[Tricky]*

- A) Application Framework
- B) Hardware Abstraction Layer (HAL)
- C) Applications
- D) Content Providers

Correct Answer: B

Explanation: The Hardware Abstraction Layer (HAL) sits above the Linux Kernel, providing standard interfaces to underlying hardware for the layers above it.

Q19. Rooting an Android device primarily results in: *[Moderate]*

- A) Enhanced built-in security
- B) Removal of manufacturer restrictions, gaining full control but weakening built-in security protections
- C) Automatic malware removal
- D) Permanent disabling of the device

Correct Answer: B

Explanation: Rooting gives superuser access and removes restrictions, but this also disables key protections like app sandboxing, making the device more vulnerable to malware.

Q20. Which of the following is the MOST common OWASP Mobile Top 10 risk related to storing tokens/passwords in plain text on a device? *[Easy]*

- A) Insecure Communication
- B) Insecure Data Storage
- C) Client Code Quality
- D) Extraneous Functionality

Correct Answer: B

Explanation: Insecure Data Storage specifically refers to sensitive data (like passwords/tokens) stored in a readable/plain format on the device.

Q21. Smishing is a social engineering attack that uses which medium? *[Easy]*

- A) Phone calls only
- B) SMS text messages
- C) Physical mail
- D) Bluetooth pairing requests only

Correct Answer: B

Explanation: 'Smishing' combines 'SMS' and 'Phishing' - it tricks victims via text messages into clicking malicious links or revealing information.

Q22. Which tool is commonly used for both static and dynamic analysis of Android apps? *[Moderate]*

- A) Wireshark
- B) MobSF (Mobile Security Framework)
- C) Nessus
- D) Nmap

Correct Answer: B

Explanation: MobSF is a dedicated framework offering both static (code-level) and dynamic (runtime) analysis of mobile applications.

Q23. What does 'Threat Risk Modelling' using STRIDE help identify? (Choose the odd one out that is NOT part of STRIDE) *[Tricky]*

- A) Spoofing
- B) Tampering
- C) Encryption
- D) Repudiation

Correct Answer: C

Explanation: STRIDE stands for Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege. 'Encryption' is not one of the STRIDE categories.

Q24. Which technique tries every possible character combination to crack a password? *[Easy]*

- A) Dictionary Attack
- B) Rainbow Table Attack
- C) Brute Force Attack
- D) Social Engineering

Correct Answer: C

Explanation: A Brute Force Attack systematically tries all possible combinations, unlike a Dictionary Attack which only tries pre-listed words.

Q25. Salting password hashes primarily helps defend against which attack? *[Tricky]*

- A) SQL Injection
- B) Rainbow Table Attacks
- C) DDoS Attacks
- D) ARP Poisoning

Correct Answer: B

Explanation: Salting adds random data to each password before hashing, making precomputed Rainbow Tables ineffective since each hash becomes unique even for identical passwords.

Q26. What is the primary purpose of Foot-printing in ethical hacking? *[Easy]*

- A) Deleting attacker's logs after an attack
- B) Gathering information about a target before an attack
- C) Encrypting stolen data
- D) Installing anti-virus software

Correct Answer: B

Explanation: Foot-printing is the reconnaissance phase - collecting as much information about the target as possible before attempting to attack it.

Q27. Which of these best describes a Zero-day vulnerability? *[Moderate]*

- A) A bug that has existed for zero days and was immediately patched
- B) A vulnerability unknown to the vendor with no official patch available yet
- C) A vulnerability found only on the first day of deployment
- D) A vulnerability that can never be exploited

Correct Answer: B

Explanation: A zero-day vulnerability is unknown to the software vendor, meaning there is no patch yet - giving defenders 'zero days' to prepare before it could be exploited.

Q28. A DDoS attack differs from a DoS attack because: *[Easy]*

- A) DDoS only affects mobile devices
- B) DDoS is launched from multiple distributed systems simultaneously, while DoS is from a single source
- C) DDoS is always legal for penetration testers
- D) There is no real difference

Correct Answer: B

Explanation: 'Distributed' Denial of Service (DDoS) involves many systems (often a botnet) attacking together, unlike a standard DoS attack from one source.

Q29. Which of the following is an example of a Covert Channel? *[Tricky]*

- A) A normal HTTPS connection to a bank's website
- B) A hidden communication path used to secretly transfer data bypassing security policy
- C) A publicly documented API endpoint
- D) A firewall log entry

Correct Answer: B

Explanation: A Covert Channel is specifically a HIDDEN communication method not intended by system design, used to secretly bypass security controls - unlike an Overt Channel, which is a normal/legitimate path.

Q30. Which HTTP-based tool feature helps a security tester automatically discover the structure of a web application? *[Moderate]*

- A) Repeater
- B) Spider (Crawler)
- C) Decoder
- D) Comparer

Correct Answer: B

Explanation: The Spider/Crawler feature (in tools like Burp Suite) automatically browses and maps out all the pages and links within a web application.

Q31. What does 'Broken Access Control' (OWASP A01:2021) commonly allow an attacker to do? *[Easy]*

- A) Encrypt the entire database
- B) Access data or functionality that should be restricted to other users/roles
- C) Physically damage server hardware
- D) Automatically patch vulnerabilities

Correct Answer: B

Explanation: Broken Access Control means the application fails to properly restrict what authenticated users can view or do, letting them access others' data or admin functionality.

Q32. Why is HTTPS important in preventing sniffing attacks like those on HTTP, FTP, or Telnet? *[Moderate]*

- A) HTTPS encrypts data in transit, making sniffed traffic unreadable without the decryption key
- B) HTTPS disables all network traffic

- C) HTTPS only works on wireless networks
- D) HTTPS prevents ARP poisoning entirely

Correct Answer: A

Explanation: Because HTTP, FTP, and Telnet send data in plain text, they are highly vulnerable to sniffing. HTTPS encrypts the traffic, so even if sniffed, the data is unreadable.

Q33. A 'Reverse-connecting Trojan' is designed to: *[Tricky]*

- A) Block all outbound connections
- B) Have the infected machine initiate a connection out to the attacker, bypassing inbound firewall restrictions
- C) Only work when the victim has no internet access
- D) Encrypt files for ransom (this describes ransomware, not this Trojan type)

Correct Answer: B

Explanation: By making the VICTIM's machine connect OUT to the attacker, this Trojan evades firewalls that typically block unsolicited INBOUND connections but allow outbound ones.

Q34. Which security testing tool type would you use to test a running/live web application from outside, without seeing its source code? *[Easy]*

- A) SAST
- B) DAST
- C) Code Review
- D) Static Analysis

Correct Answer: B

Explanation: DAST (Dynamic Application Security Testing) is a black-box approach that tests the running application from the outside, without access to the source code.

Q35. What best defines Penetration Testing? *[Easy]*

- A) Illegally hacking any system for personal gain
- B) An authorized, simulated cyberattack performed to evaluate a system's security
- C) Only scanning a network without any exploitation
- D) Writing anti-virus signatures

Correct Answer: B

Explanation: Penetration Testing is a legally authorized, simulated attack aimed at finding and demonstrating real security weaknesses before actual attackers can exploit them.

Q36. Which of these is a valid reason 'Insecure Communication' appears in OWASP Mobile Top 10? *[Easy]*

- A) The app uses HTTPS with certificate pinning
- B) The app sends sensitive data over the network without proper encryption (no HTTPS/TLS)
- C) The app never connects to the internet
- D) The app uses biometric authentication

Correct Answer: B

Explanation: Insecure Communication specifically refers to sending sensitive data without adequate encryption, exposing it to interception during transmission.

Q37. What is the primary risk of using outdated/vulnerable software components (OWASP A06:2021)? *[Easy]*

- A) They run faster than updated components
- B) They may contain publicly known security flaws that attackers can easily exploit
- C) They automatically encrypt all data
- D) They are always more secure than newer versions

Correct Answer: B

Explanation: Outdated components often have publicly disclosed vulnerabilities (with known exploits), making them easy targets if not updated/patched.

Q38. Which technique would an attacker use to identify the Operating System running on a remote target machine? *[Moderate]*

- A) Social Engineering
- B) OS Fingerprinting
- C) Phishing
- D) Buffer Overflow

Correct Answer: B

Explanation: OS Fingerprinting analyses how a system responds to certain network probes/packets to determine its underlying operating system.

Q39. Why is Blind (Time-based) SQL Injection considered more difficult to exploit than Error-based SQLi? *[Tricky]*

- A) It requires physical access to the server
- B) No direct data or error is shown; the attacker must infer information indirectly (e.g., via response time)
- C) It only works on mobile applications
- D) It cannot extract any data at all

Correct Answer: B

Explanation: In Blind SQLi, the application doesn't show errors or data directly - the attacker must ask true/false questions and infer answers from indirect signals like page behaviour or response delay.

Q40. What does 'Extraneous Functionality' mean in the context of OWASP Mobile Top 10? *[Tricky]*

- A) Extra security features that make the app safer
- B) Hidden backdoor/debug features accidentally left in the production app
- C) Additional encryption layers
- D) Extra permissions requested transparently from the user

Correct Answer: B

Explanation: Extraneous Functionality refers to leftover hidden features (like debug backdoors) that developers forgot to remove before releasing the app, which attackers can discover and exploit.

Q41. Which of these best summarizes the purpose of a Threat Risk Model like STRIDE? *[Moderate]*

- A) To encrypt all application data automatically
- B) To systematically identify and categorize potential security threats during design
- C) To replace the need for penetration testing
- D) To generate strong passwords for users

Correct Answer: B

Explanation: STRIDE provides a structured framework to think through possible threats (Spoofing, Tampering, Repudiation, etc.) during the design phase, helping teams build more secure systems proactively.

SELF-TEST QUIZ (30 Questions)

Attempt this quiz like a real exam - answers are NOT shown next to the questions. Write down your answers first, then check the Answer Key at the end of this section to score yourself. (Read this carefully)

1. Which OWASP category deals with weak login and session mechanisms?
 - A) Injection
 - B) Identification and Authentication Failures
 - C) Security Misconfiguration
 - D) SSRF
2. What does DOM-based XSS exploit?
 - A) The database directly
 - B) Client-side JavaScript and the page's DOM
 - C) The server's operating system
 - D) Wireless encryption
3. Which type of SQL Injection relies on observing response time to extract data?
 - A) Union-based
 - B) Error-based
 - C) Blind/Time-based
 - D) Reflected
4. A buffer overflow is best prevented by:
 - A) Ignoring input length
 - B) Proper input validation
 - C) Disabling firewalls
 - D) Using weaker passwords
5. Which tool feature lets a tester manually resend and tweak a single HTTP request?
 - A) Spider
 - B) Repeater
 - C) Scanner
 - D) Decoder
6. SAST is best described as:
 - A) Black-box, runtime testing
 - B) White-box, source-code-level testing
 - C) A type of firewall
 - D) A password cracking method
7. Which principle of the CIA Triad ensures data is not altered without authorization?
 - A) Confidentiality
 - B) Integrity
 - C) Availability
 - D) Accountability
8. What is the correct first phase of ethical hacking?
 - A) Scanning
 - B) Gaining Access

- C) Reconnaissance
- D) Covering Tracks

9. A Red Team in security exercises represents:

- A) The defenders
- B) The simulated attackers
- C) The legal department
- D) The customer support team

10. Which scan sends packets with absolutely no flags set?

- A) XMAS Scan
- B) NULL Scan
- C) SYN Scan
- D) IDLE Scan

11. What best distinguishes a Worm from a Virus?

- A) Worms need a host file
- B) Worms self-replicate across networks without human action
- C) Viruses spread faster than worms
- D) Viruses cannot infect Windows

12. ARP Poisoning is mainly used to enable which kind of attack?

- A) Man-in-the-Middle sniffing on a switched network
- B) Remote code execution on a database
- C) Wireless signal jamming
- D) Password brute-forcing

13. Which system actively BLOCKS malicious traffic in real time?

- A) IDS
- B) IPS
- C) Honeypot
- D) Proxy Server

14. A Smurf Attack abuses which protocol to flood a victim?

- A) ICMP
- B) SMTP
- C) FTP
- D) SSH

15. Which best explains Session Hijacking?

- A) Guessing a password before login
- B) Taking over an already-authenticated, active session
- C) Sending spam emails
- D) Encrypting a hard drive

16. WEP is considered weak mainly because:

- A) It cannot connect to routers
- B) Its encryption can be cracked quickly with known tools
- C) It is too slow to use
- D) It requires biometric login

- 17.** A Honeypot's main purpose is to:
 - A) Encrypt outgoing emails
 - B) Attract and study attackers using a decoy system
 - C) Speed up network traffic
 - D) Replace antivirus software
- 18.** Dynamic malware analysis involves:
 - A) Reading code without execution
 - B) Running the malware in an isolated/sandboxed environment
 - C) Deleting the malware immediately
 - D) Encrypting the malware sample
- 19.** In Android's architecture, which layer is closest to the hardware?
 - A) Application Framework
 - B) Linux Kernel
 - C) Applications
 - D) Android Runtime
- 20.** Rooting an Android device generally:
 - A) Improves built-in security automatically
 - B) Removes restrictions and weakens built-in security protections
 - C) Is required to install any app
 - D) Permanently disables the device
- 21.** Storing user passwords in plain text on a mobile device is an example of:
 - A) Insecure Communication
 - B) Insecure Data Storage
 - C) Client Code Quality issue only
 - D) Extraneous Functionality
- 22.** Smishing attacks are delivered primarily through:
 - A) Phone hardware defects
 - B) SMS text messages
 - C) USB cables
 - D) Bluetooth pairing only
- 23.** MobSF is used for:
 - A) Static and dynamic analysis of mobile apps
 - B) Cracking WiFi passwords only
 - C) Managing firewalls
 - D) Editing APK icons only
- 24.** Which of these is NOT part of the STRIDE threat model?
 - A) Spoofing
 - B) Tampering
 - C) Firewalling
 - D) Elevation of Privilege
- 25.** Brute Force attacks differ from Dictionary attacks because they:
 - A) Only use common words

- B) Try every possible character combination
- C) Require no computing power
- D) Only work on mobile devices

26. Salting password hashes primarily defeats:

- A) SQL Injection
- B) Rainbow Table attacks
- C) DDoS attacks
- D) Phishing

27. Foot-printing is best described as:

- A) Covering an attacker's tracks
- B) Gathering information about a target before attacking
- C) Installing patches on a server
- D) Encrypting stolen files

28. A Zero-day vulnerability is one that:

- A) Has existed for zero days total
- B) Is unknown to the vendor with no patch yet available
- C) Was fixed on day one
- D) Only affects zero users

29. DDoS differs from DoS because it:

- A) Uses multiple distributed systems to attack simultaneously
- B) Only works on mobile networks
- C) Is always legal
- D) Cannot target web servers

30. A Reverse-connecting Trojan is designed to:

- A) Block all inbound traffic
- B) Have the victim machine connect out to the attacker, bypassing inbound firewall rules
- C) Work only offline
- D) Encrypt the attacker's own files

Answer Key - Self-Test Quiz

Check your answers below. Score yourself: 25-30 correct = Excellent, 18-24 = Good (revise weak topics), below 18 = Revise the Unit notes again before moving on.

Q#	Ans	Q#	Ans	Q#	Ans
1	B	11	B	21	B
2	B	12	A	22	B
3	C	13	B	23	A
4	B	14	A	24	C
5	B	15	B	25	B
6	B	16	B	26	B
7	B	17	B	27	B
8	C	18	B	28	B
9	B	19	B	29	A
10	B	20	B	30	B